THREAT ADVISORY

GitLab's Critical RCE Flaw Reaches Back to Version 7.0

GitLab has released critical security updates for **CVE-2026-110264**, a vulnerability that could allow unauthenticated remote code execution on affected CE and EE servers. Rated CVSS 10.0, the flaw affects releases dating back to GitLab 7.0. Administrators of self-managed installations are urged to update immediately, while GitLab.com is already patched.

Sources: **GitLab** · **CERT-EU** · 22 Oct 2026
CVE-2026-110264 · CVSS 3.1: 10.0 · GitLab CE/EE

THREAT ADVISORY

Critical exposure in self-managed GitLab

CVE-2026-110264 / COMMUNITY & ENTERPRISE EDITIONS

GitLab released critical security updates on **21 October 2026** to address **CVE-2026-110264**, an integer overflow vulnerability that could allow unauthenticated remote code execution (RCE) on affected Community Edition (CE) and Enterprise Edition (EE) servers.

The issue involves an integer overflow during the compilation of a specially crafted regular expression. GitLab has not fully disclosed the conditions required for exploitation.

Affected releases extend back to **GitLab 7.0**. GitLab urges self-managed customers to update immediately, while CERT-EU recommends prioritising internet-facing installations and assessing affected systems for potential compromise.

10.0
CRITICAL
CVSS 3.1

12 VULNERABILITIES ADDRESSED

The security release addresses one critical, two high-severity, five medium-severity and four low-severity issues.

The affected versions and fixed releases are listed on page 4.

TECHNICAL DETAILS

Attack requirements and disclosure limits

CVSS 3.1 VECTOR

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

ATTACK VECTOR

Network

ATTACK COMPLEXITY

Low

PRIVILEGES REQUIRED

None

USER INTERACTION

None

The assessment identifies high potential impacts on **confidentiality, integrity and availability**.

GitLab credits security researcher **joaxcar** with reporting the vulnerability through its HackerOne bug bounty programme.

WHAT THE ADVISORY DOES NOT ESTABLISH

The vendor describes exploitation as possible under certain conditions but does not fully document those conditions in the patch advisory. This limits the ability to rule out exposure based solely on configuration or assumptions about feature usage.

The CVSS rating reflects potential severity, not confirmed exploitation. The advisory does not establish that the vulnerability has been exploited in the wild or that a public exploit is available.

AFFECTED VERSIONS

Affected versions and fixes

The following version ranges apply to both GitLab CE and EE:

AFFECTED VERSION	FIXED RELEASE
7.0 to before 18.11.13	**18.11.13**
19.0.x before 19.0.10	**19.0.10**
19.1.x before 19.1.9	**19.1.9**
19.2.x before 19.2.9	**19.2.9**
19.3.x before 19.3.6	**19.3.6**
19.4.x before 19.4.3	**19.4.3**
19.5.x before 19.5.1	**19.5.1**

These releases contain the correction for CVE-2026-110264. GitLab backported the critical fix to four older release branches beyond its standard patch releases.

Administrators should distinguish the RCE fix from the other vulnerabilities addressed in the same announcement. Older backported releases should not be assumed to contain all 11 additional security fixes. Two notable issues are:

CVE-2026-15723 / CVSS 8.2

An authentication flaw that could allow an authenticated attacker to take over an existing LDAP-backed account when OmniAuth SAML and LDAP auto-linking are both enabled.

CVE-2026-112212 / CVSS 7.5

Cache poisoning affecting OAuth/OIDC discovery endpoints that, in deployments using a shared cache, could redirect certain authentication flows to an attacker-controlled server.

DEPLOYMENT & RESPONSE

Deployment and response

GitLab.com is already running a patched version. **GitLab Dedicated** tenants running **19.3.5-internal0**, **19.4.2-internal0**, or later already include the relevant fixes and require no action for this release.

Self-managed installations must follow the appropriate upgrade process. Systems on substantially older versions may require several intermediate upgrades before reaching a fixed release.

POTENTIAL IMPACT

CVE-2026-110264 presents a significant risk because successful unauthenticated code execution could compromise a development platform.

Depending on the permissions and resources available to the affected process, potential consequences include unauthorised access to source code, exposure of accessible credentials, and interference with development or CI/CD workflows. These are impact scenarios rather than confirmed outcomes.

A maximum CVSS 3.1 rating, potential unauthenticated RCE and a broad affected-version range justify urgent remediation even without confirmed active exploitation. Organisations operating self-managed GitLab should identify affected instances, prioritise patch deployment, preserve relevant security logs and investigate signs of suspicious activity.

Updating affected self-managed GitLab installations is the primary remediation action. Internet-facing instances should receive particular priority, although network isolation alone does not eliminate the vulnerability.

Before upgrading, administrators should review GitLab's version-specific upgrade guidance, establish a tested rollback procedure, and preserve recoverable backups together with configuration files and secrets.

REMEDIATION & VERIFICATION

Migrations and verification

GitLab requires administrators to follow applicable intermediate upgrade stops and allow background database migrations to complete before proceeding.

DATABASE MIGRATIONS IN THIS RELEASE

VERSION	MIGRATION TYPE
19.3.6	**Regular**
19.4.3	**Regular and post-deployment**

GitLab warns that the relevant migration-bearing upgrades **will cause downtime on single-node installations**, because migrations must complete before GitLab can start. Properly planned multi-node deployments may support zero-downtime upgrades.

VERIFY THE RUNNING INSTALLATION

Pre- and post-upgrade verification should include GitLab health checks, migration status, successful user authentication, repository read/write operations, and relevant CI/CD runner functionality. Administrators should also confirm that the deployed instance reports the intended fixed version.

IF PATCHING IS DELAYED

Where immediate updating is not possible, restricting access to trusted networks or a VPN can reduce external exposure. However, this should be treated as temporary risk reduction rather than a verified, vulnerability-specific workaround.

EXPLOITATION STATUS & INVESTIGATION

Exploitation status and investigation clues

The official advisories reviewed do not establish a confirmed exploitation campaign.

GITLAB DETECTION REFERENCES

Onigmo native worker crash
Org mode render error burst

GitLab released these two detection rules for self-managed installations to support investigations into potential exploitation attempts.

Administrators should review relevant application logs, correlate related requests where possible, and investigate unusual process failures or rendering errors.

Further investigation may include unexpected administrator accounts, newly created access tokens or deploy keys, unusual repository activity, and unauthorised pipeline configuration changes.

These additional indicators are not unique to CVE-2026-110264. A worker crash or rendering error alone does not establish successful exploitation, while an absence of alerts does not conclusively rule out compromise.

REMEDIATION AND EVIDENCE

Applying the update remediates the vulnerability; it does not establish whether an installation was compromised before patching. Remediation should be accompanied by a review of available evidence for potential pre-patch compromise.

Stay vigilant. **Follow Memori CTI for more threat intel.**